



정보보호

제품군



실습훈련

기초 ② 시스템 모의해킹



기초②

시스템 권한탈취

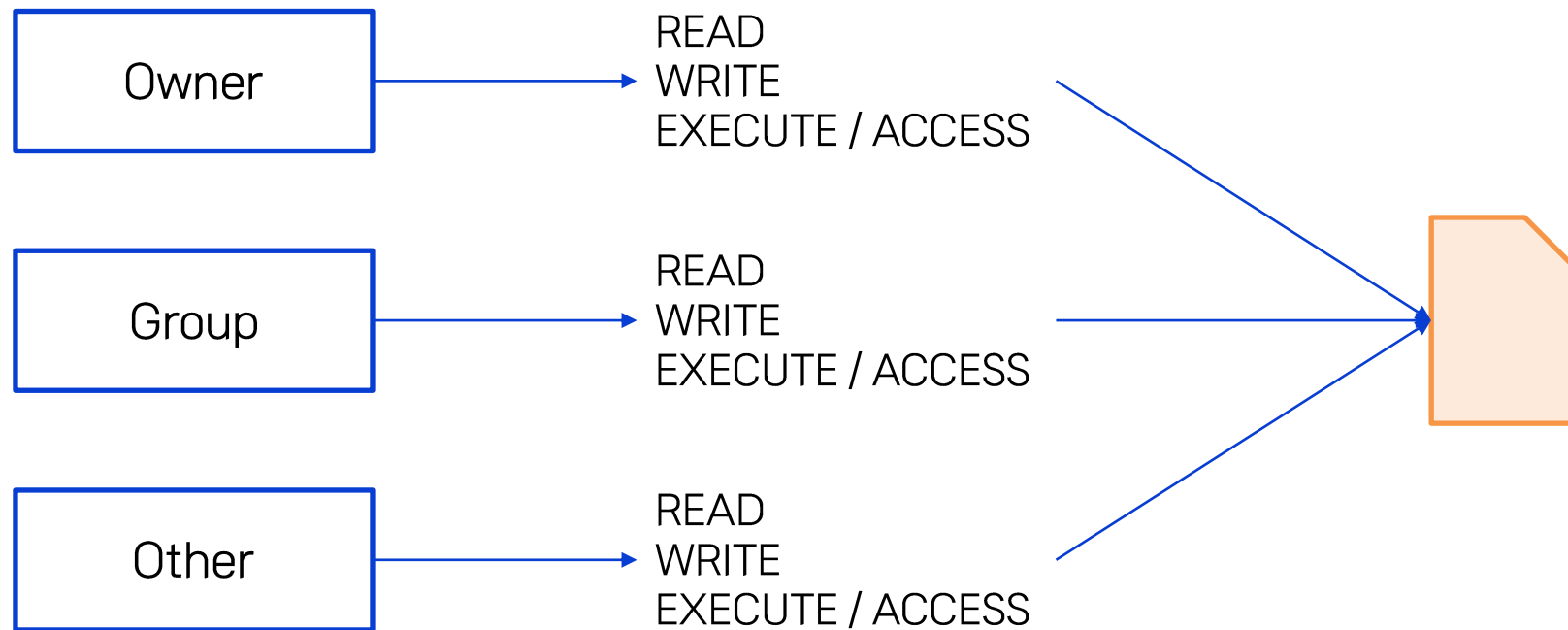
- 시스템 권한탈취 개요
- 레이스 컨디션 개요

[기초2] 시스템 권한 탈취 - 시스템 권한

시스템 권한

■ 권한이란?

- 시스템, 네트워크, 애플리케이션과 같은 환경에서의 특정 리소스나 기능, 파일 등에 액세스(읽기/쓰기/실행)할 수 있는 자격



[기초2] 시스템 권한 탈취 – 시스템 권한 탈취 개요

시스템 권한 탈취 개요

■ 시스템 권한 탈취란?

- 다른 사람의 통신망이나 컴퓨터 시스템에 정당한 접근 권한 없이 접근하거나 허용된 접근 권한의 범위를 초과하여 침입하는 행위를 말한다.
- 권한 상승 역시 보안 경계를 침해하는 행위 중 하나로서 시스템 권한 탈취와 유사한 공격으로 관리자가 의도한 정도보다 더 많은 권한, 시스템이나 애플리케이션에 대한 더 높은 액세스 권한을 획득하는 행위입니다.
- CVE-2021-3156: Heap-Based Buffer Overflow in Sudo (Baron Samedit)
sudo에서 힙 오버플로우 취약점을 발견했습니다. 권한이 없는 모든 사용자는 이 취약점을 악용하여 기본 sudo 구성을 사용하여 취약한 호스트에 대한 루트 권한을 얻을 수 있습니다.
sudo란? Sudo는 대부분의 Unix 및 Linux 기반 OS에 포함된 강력한 유틸리티입니다.

[기초2] 시스템 권한 탈취 – 레이스 컨디션 개요

레이스 컨디션

■ 레이스 컨디션이란?

- 두 개 이상의 프로세스가 공용 자원을 병행적으로(concurrently) 읽거나 쓸 때, 공용 데이터에 대한 접근이 어떤 순서에 이루어졌는지에 따라 그 실행 결과가 달라지는 상황을 말한다.
- 예를 들어, 프로세스 A와 B가 존재하는 병렬시스템 환경에서 프로세스 A는 자원사용(파일 읽기)에 앞서 해당 자원(파일)의 존재여부를 검사한다. 이때 프로세스 B가 해당 자원(파일)을 아직 사용(삭제)하지 않았기 때문에, 프로세스 A는 해당 자원(파일)이 존재한다고 판단한다. 그러나 프로세스 A가 자원 사용(파일읽기)을 시도하는 시점에 해당 자원(파일)은 사용 불가능 상태이기 때문에 여러 가지 문제(오류발생, 권한탈취)가 발생할 수 있습니다.
- 요약하면, 멀티스레드 환경에서 공유자원에 여러프로세스가 사용해 동시 접근이 가능할 때 발생하는 상황이다.

Ex1)

deposit(100) 호출 : (account: 0)
deposit(100) 종료 : (account: 100)
withdraw(100) 호출 : (account: 100)
withdraw(100) 종료 : (account: 100)

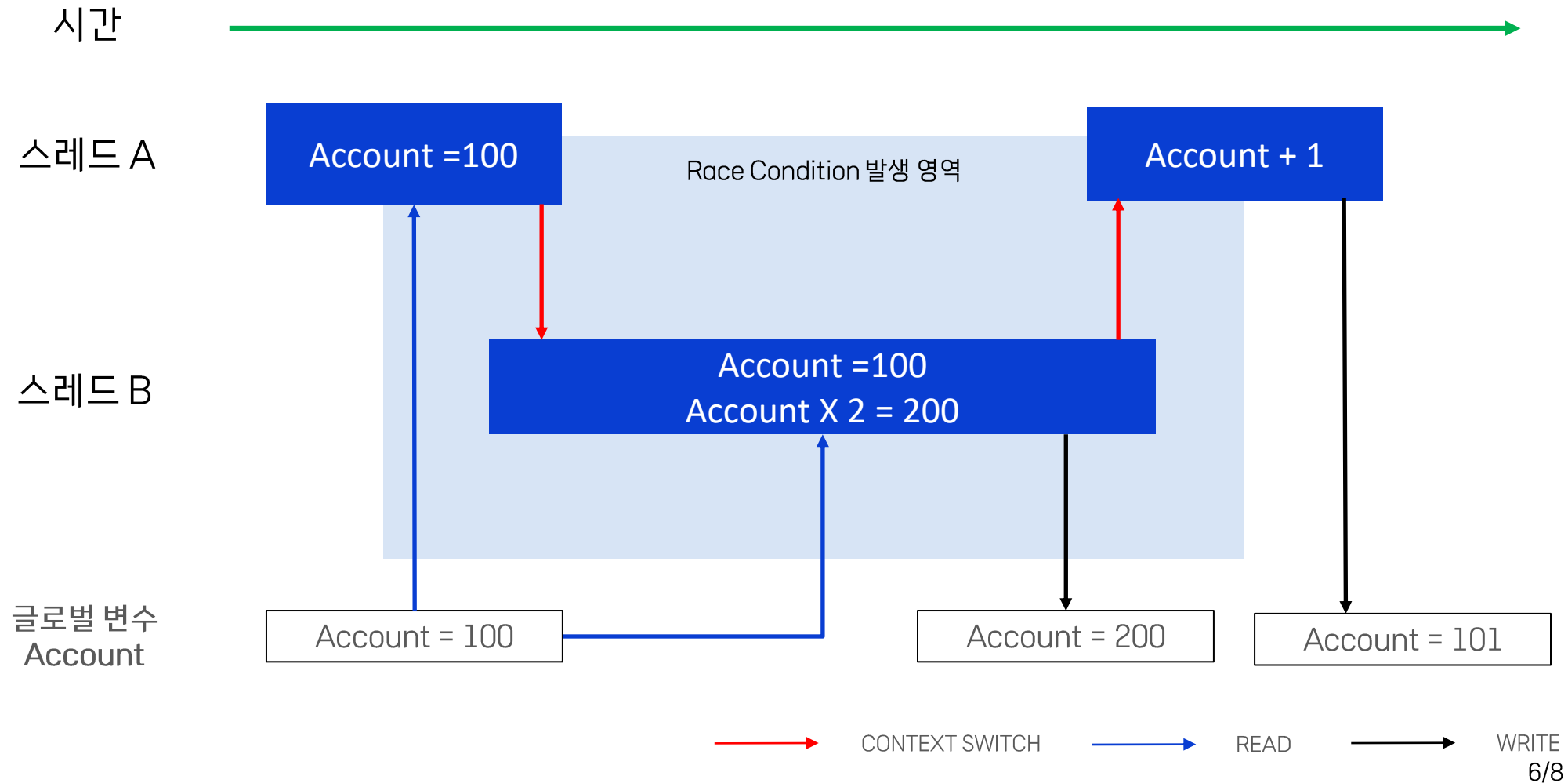
Ex2)

deposit(100) 호출 : (account: 0)
withdraw(100) 호출 : (account: 0)
deposit(100) 종료 : (account: 100)
withdraw(100) 종료 : (account: -100)

[기초2] 시스템 권한 탈취 - 레이스 컨디션 공격 원리

레이스 컨디션

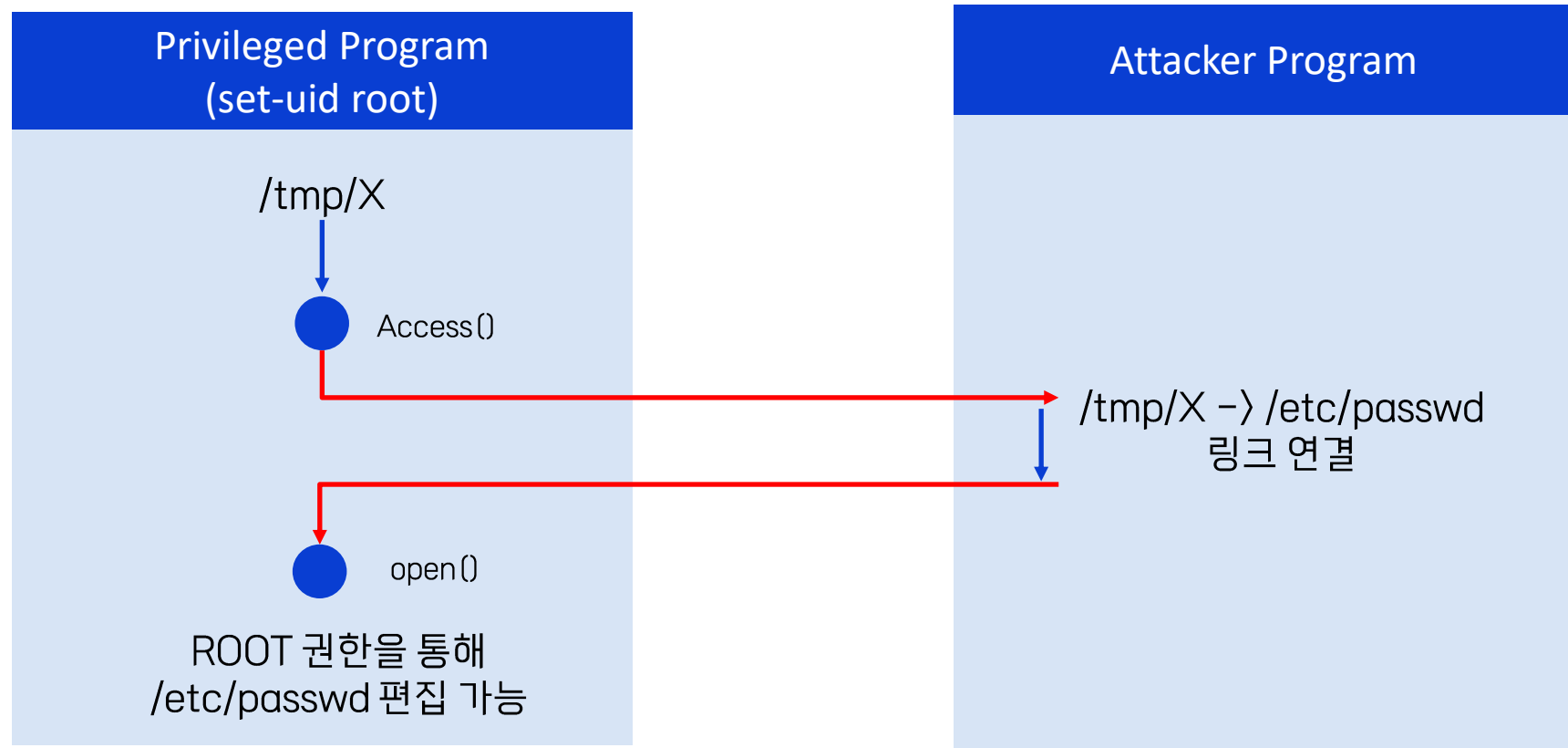
■ 레이스 컨디션 공격 원리 #1



[기초2] 시스템 권한 탈취 - 레이스 컨디션 공격 원리

레이스 컨디션

■ 레이스 컨디션 공격 원리 #2



`/tmp/X` : 공격자 소유의 파일

`/etc/passwd` : 공격자 소유가 아닌 권한이 없는 파일

[기초2] 시스템 권한 탈취 - 해결방안

레이스 컨디션

■ 레이스 컨디션 예방 방법

- 공유자원(예: 파일)을 여러 프로세스가 접근하여 사용할 경우, 동기화 구문을 사용해 한번에 하나의 프로세스만 접근 가능하도록(synchronized, mutex 등) 하는 한편 성능에 미치는 영향을 최소화 하기 위해 임계 코드 주변만 동기화 구문을 사용합니다.